

SecCheck 기능 및 화면 가이드 (Features & UI Guide)

SecCheck 는 Excel 기반 보안성 심의 업무를 템플릿·버전·제출 스냅샷·항목별 검토로 체계화한 **엔터프라이즈 오프라인 운영형 보안 검토 플랫폼**입니다.

🔍 전체 메뉴별 주요 화면 및 기능 명세

1. 인증 및 로그인 (/login)

SecCheck
SECURITY REVIEW PLATFORM

안전한 서비스의 시작

보안성 심의 체크리스트와 증적, 검토·승인 이력을 하나의 흐름으로 관리합니다.

아이디 *

비밀번호 *

로그인 →

SecCheck v0.1.0

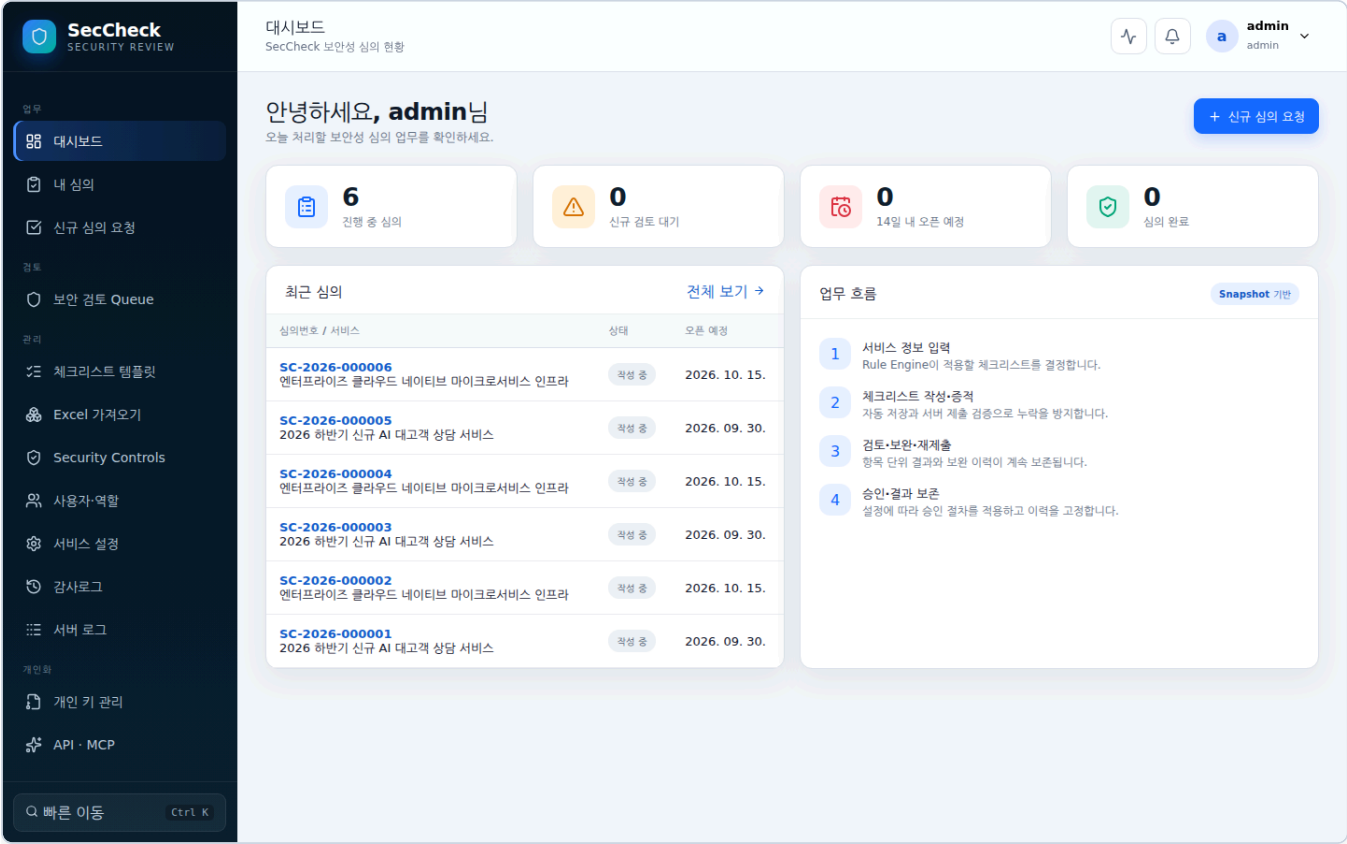
Excel 업무를 넘어 추적 가능한 Security Control로.

템플릿 버전과 제출 스냅샷을 분리하고, 모든 작성·검토·승인 행위를 감사 가능한 이력으로 보존합니다.

심의 요청 → 체크리스트 작성 → 검토·승인

- 로컬 부트스트랩 관리자: 초기 4대 환경변수(`BOOTSTRAP_ADMIN` , `BOOTSTRAP_ADMIN_PASSWORD`) 기반 보안 로그인
- Keycloak OIDC SSO: 설정 시 사내 SSO로 로그인 버튼을 통한 통합 인증 연동
- 서비스 브랜드 & 버전: 현재 릴리스 버전(`v0.1.0`) 및 서비스명 실시간 표시

2. 보안 심의 대시보드 (/ , /dashboard)



- **핵심 KPI 현황 카드**: 진행 중 심의(Active), 신규 검토 대기/미처리 보완 요청(Pending), 14일 내 오픈 예정, 심의 완료 통계
- **최근 심의 테이블**: 최근 요청된 심의의 심의번호, 서비스명, 상태, 오픈 예정일 요약
- **업무 흐름 가이드**: 서비스 정보 입력 → 체크리스트 작성·증적 → 검토·보완·재제출 → 승인·결과 보존 4단계 Snapshot 프로세스 안내

3. 보안성 심의 목록 (/reviews)

SecCheck
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자 역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

Q 빠른 이동 Ctrl K

심의 관리
작성·제출·보완 상태를 관리합니다

admin

admin

심의 목록
권한이 있는 심의 건만 표시됩니다.

+ 신규 심의

Q 심의번호, 서비스명, 부서 검색

전체 상태

심의번호	서비스	유형	담당 부서	오른 예정	상태
SC-2026-000006	엔터프라이즈 클라우드 네이티브 마이크로서비스 인프라	INTERNAL · NEW	인프라보안운영팀	2026. 10. 15.	작성 중 상세
SC-2026-000005	2026 하반기 신규 AI 대고객 상담 서비스	EXTERNAL · NEW	AI혁신플랫폼팀	2026. 09. 30.	작성 중 상세
SC-2026-000004	엔터프라이즈 클라우드 네이티브 마이크로서비스 인프라	INTERNAL · NEW	인프라보안운영팀	2026. 10. 15.	작성 중 상세
SC-2026-000003	2026 하반기 신규 AI 대고객 상담 서비스	EXTERNAL · NEW	AI혁신플랫폼팀	2026. 09. 30.	작성 중 상세
SC-2026-000002	엔터프라이즈 클라우드 네이티브 마이크로서비스 인프라	INTERNAL · NEW	인프라보안운영팀	2026. 10. 15.	작성 중 상세
SC-2026-000001	2026 하반기 신규 AI 대고객 상담 서비스	EXTERNAL · NEW	AI혁신플랫폼팀	2026. 09. 30.	작성 중 상세

- 다차원 실시간 검색 & 필터링: 심의번호, 서비스명, 담당 부서 키워드 검색 및 상태 필터(작성 중, 제출 완료, 재제출, 검토 중, 보완 요청, 승인 대기, 심의 완료, 반려)
- 신규 심의 요청: 상단 **신규 심의** 버튼을 통한 즉시 요청 생성

4. 신규 보안성 심의 요청 (/reviews/new)

SecCheck
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자 역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

신규 심의

서비스 정보를 기준으로 체크리스트가 자동 배경됩니다

admin

admin

신규 보안성 심의 요청

서비스 특성을 정확히 입력하면 Rule Engine이 게시된 템플릿에서 항목을 스냅샷으로 배경합니다.

돌아가기

서비스 기본정보

서비스명 *

담당 부서 *

서비스 설명 *

서비스 유형 *

신규·변경 구분 *

구축 담당자 *

개발 담당자 *

운영 담당자

오픈 예정일

대내·대외 여부 *

업무 중요도

적용 조건

체크리스트 자동 배경 입력값

관리자 페이지 존재

개인정보 처리

- 서비스 기본정보: 서비스명, 담당 부서, 서비스 설명, 서비스 유형(대내/대외/관리자/배치), 신규·변경 구분, 구축·개발·운영 담당자, 오픈 예정일, 업무 중요도
- Rule Engine 적용 조건:
 - 관리자 페이지 존재, 개인정보 처리, 개인신용정보 처리, 외부 고객 서비스, 클라우드 사용, Docker 사용, Kubernetes 사용, 외부기관 연계, 인터넷 통신 여부
- 지능형 스냅샷 자동 배경: 품 제출 즉시 Rule Engine이 조건에 부합하는 게시 템플릿의 항목들을 불변 스냅샷으로 배경

5. 심의 상세 & 체크리스트 작업 공간 (/reviews/:id)

SecCheck SECURITY REVIEW

심의 상세
체크리스트 작성과 검토 이력을 확인합니다

← 목록

작성 중 | 재심의 복사 | 자동 배경 조정 | 요청 취소 | **제출**

2026 하반기 신규 AI 대고객 상담 서비스
SC-2026-000005 · AI혁신플랫폼팀 · EXTERNAL

작성 진행률: **1%** (2/210)

검토 집계: 적합 0 | 조건부 0 | 미흡·부적합 0 | N/A 1

↓ Excel | ↓ PDF | ↓ ZIP

Q 항목코드, 보안요건, 질문 검색 | 전체 항목

섹션 이동 (210)

- Docker 보안 · Docker Configuration
- Docker 보안 · 호스트 OS
- Docker 보안 · 이미지
- Docker 보안 · Docker Swarm
- Docker 보안 · 기타
- Kubernetes 보안 · Master Node / API Server Configuration
- Kubernetes 보안 · Master Node / etcd Configuration
- Kubernetes 보안 · Master Node / Controller Manager Configuration
- Kubernetes 보안 · Master Node / PodSecurityPolicy Configuration
- Kubernetes 보안 · Master Node / Host OS
- Kubernetes 보안 · Master Node / ...

Docker 보안 · Docker Configuration V1.0

1-1 CRITICAL **호스트 OS 주요 자원 접근 제어**
컨테이너 구성 시 컨테이너가 호스트 OS의 주요 자원에 접근 가능하도록 설정된 경우, 컨테이너에서 호스트 OS의 주요 자원에 대한 수정으로 인해 해당 호스트 및 호스트에서 실행되는 다른 컨테이너의 안정성과 보안에 영향을 미칠 수 있음 - 주요 시스템 디렉터리 마운트 금지 - 호스트 장치 파일 컨테이너에 직접 노출 금지

1-2 CRITICAL **인증·권한 제어**
docker group 내 신뢰할 수 있는 사용자만 존재하는지 확인 및 authorization plugin 을 별도로 설정 후 사용하거나 운영 환경에 따라 Kubernetes, Cloud Foundry 등과 같은 외부의 프로그램 내의 인증·권한 관리 기능을 활용하여 Docker 가 인증·권한 제어를 할 수 있도록 구축

1-3 CRITICAL **SSL/TLS 적용**
daemon을 TCP Socket을 통해 네트워크에 연결 후 원격으로 접속하도록 구축하는 경우에는 SSL/TLS 프로토콜을 적용을 통해 네트워크상에서

항목 상세 (1-1)

호스트 OS 주요 자원 접근 제어
컨테이너 구성 시 컨테이너가 호스트 OS의 주요 자원에 접근 가능하도록 설정된 경우, 컨테이너에서 호스트 OS의 주요 자원에 대한 수정으로 인해 해당 호스트 및 호스트에서 실행되는 다른 컨테이너의 안정성과 보안에 영향을 미칠 수 있음 - 주요 시스템 디렉터리 마운트 금지 - 호스트 장치 파일 컨테이너에 직접 노출 금지

점검 가이드

[진단에서]
- 주요 시스템 디렉터리 마운트 금지
: 각 컨테이너에 매핑된 디렉터리의 목록과 권한 확인
`docker ps --quiet --all | xargs docker inspect --format '{{.Id}}: Volumes={{.Mounts}}'`
- 호스트 장치 파일 컨테이너에 직접 노출 금지
: 컨테이너 내 불필요하게 접근 가능한 호스트 장치의 존재 여부 및 필요에 의해 접근 가능한 장치에 대한 권한이 올바르게 설정되어 있는지 확인
`docker ps --quiet --all | xargs docker inspect --format '{{.Id}}:`

- 작성 진행률 & 검토 집계 바: 총 항목 대비 작성률(%), 적합/조건부/미흡/N/A 집계 실시간 표시
- 1클릭 다중 포맷 내보내기: Excel (.xlsx), PDF (.pdf), ZIP 결과물 즉시 다운로드
- 섹션 네비게이션 & 항목 필터: 템플릿/섹션별 빠른 이동 및 미작성, N/A, 중적 누락, 보완 요청 항목 필터

6. 체크리스트 항목 편집 & 증적 암호화 업로드

SecCheck SECURITY REVIEW

심의 상세
체크리스트 작성과 검토 이력을 확인합니다

← 목록

작성 중 | 재심의 복사 | 자동 배경 조정 | 요청 취소 | 제출

2026 하반기 신규 AI 대고객 상담 서비스
SC-2026-000005 · AI혁신플랫폼팀 · EXTERNAL

작성 진행률
1% (2/210)

검토 집계
적합 0 | 조건부 0 | 미흡·부적합 0
N/A 1

Excel | PDF | ZIP

항목코드, 보안요건, 질문 검색 | 전체 항목

섹션 이동 210

- Docker 보안 · Docker Configuration
- Docker 보안 · 호스트 OS
- Docker 보안 · 이미지
- Docker 보안 · Docker Swarm
- Docker 보안 · 기타
- Kubernetes 보안 · Master Node / API Server Configuration
- Kubernetes 보안 · Master Node / etcd Configuration
- Kubernetes 보안 · Master Node / Controller Manager Configuration
- Kubernetes 보안 · Master Node / PodSecurityPolicy Configuration
- Kubernetes 보안 · Master Node / Host OS
- Kubernetes 보안 · Master Node / ...

Docker 보안 · Docker Configuration V1.0

1-1 CRITICAL

호스트 OS 주요 자원 접근 제어

컨테이너 구성 시 컨테이너가 호스트 OS의 주요 자원에 접근 가능하도록 설정된 경우, 컨테이너에서 호스트 OS의 주요 자원에 대한 수정으로 인해 해당 호스트 및 호스트에서 실행되는 다른 컨테이너의 안정성과 보안에 영향을 미칠 수 있음 - 주요 시스템 디렉터리 마운트 금지 - 호스트 장치 파일 컨테이너에 직접 노출 금지

적용 여부 * | 자체 판단

Y | N | N/A | 적합

현황 및 증적

사내 SSO 및 OAuth2 PKCE 표준 인증 흐름을 적용 완료하였으며 테스트 검증을 완료했습니다.

조치 계획

운영 배포 전 보안 관제 로그 연동 예정

항목 상세 1-1

호스트 OS 주요 자원 접근 제어

컨테이너 구성 시 컨테이너가 호스트 OS의 주요 자원에 접근 가능하도록 설정된 경우, 컨테이너에서 호스트 OS의 주요 자원에 대한 수정으로 인해 해당 호스트 및 호스트에서 실행되는 다른 컨테이너의 안정성과 보안에 영향을 미칠 수 있음 - 주요 시스템 디렉터리 마운트 금지 - 호스트 장치 파일 컨테이너에 직접 노출 금지

점검 가이드

[진단예시]

- 주요 시스템 디렉터리 마운트 금지
- 각 컨테이너에 매핑된 디렉터리의 목록과 권한 확인

```
docker ps --quiet --all | xargs docker inspect --format '{{.Id}}: Volumes={{.Mounts}}'
```

- 호스트 장치 파일 컨테이너에 직접 노출 금지
- 컨테이너 내 불필요하게 접근 가능한 호스트 장치의 존재 여부 및 필요에 의해 접근 가능한 장치에 대한 권한이 올바르게 설정되어 있는지 확인

```
docker ps --quiet --all | xargs docker inspect --format '{{.Id}}:
```

- 적용 여부 & 자체 판단: Y, N, N/A 원클릭 선택 및 적합/미흡 자체 평가
- N/A 사유 & 현황 작성: N/A 선택 시 필수 사유 입력 및 조치 계획 수립
- 실시간 자동 저장: 타이핑 시 수초 내 백그라운드 자동 저장 및 상태 알림
- 증적 첨부 (AES-256-GCM): 증적 파일 업로드 시 Magic/MIME 검증, SHA-256 해시 생성, 개인 데이터 키 버전 기반 AES-256-GCM 암호화 보관

7. 자동 배정 결과 수동 조정 (Rule Override)

자동 배정 결과 조정

닫기

최초 제출 전 자동 Rule 결과만 조정할 수 있으며, 수동 변경 사유와 작업자는 감사로그에 영구 기록됩니다.

작업

자동 배정에서 제외

체크리스트 항목 *

선택

수동 변경 사유 *

취소 변경 적용

- 규칙 예외 처리: 서비스 특성에 따라 자동 배정된 항목을 제외하거나 미배정 항목을 수동 포함
- 불변 감사 추적: 수동 변경 사유, 작업자, 시각을 감사로그에 영구 기록

8. 보안 검토 Queue (/security)

SecCheck SECURITY REVIEW

보안 검토 Queue
신규 제출과 보완 건을 검토합니다

admin

보안 검토 Queue
제출·재제출된 건을 시작하고 항목별 검토를 진행하세요.

Q 심의회호, 서비스명, 부서 검색

제출 완료

조건에 맞는 심의가 없습니다.
필터를 바꾸거나 신규 심의를 요청하세요.

빠른 이동 Ctrl K

- 보안 담당자 전용 대기열: 제출(SUBMITTED) 및 재제출(RESUBMITTED)된 심의 건을 집중 관리하고 검토 시작 및 항목별 검토 의견/보완 요청 등록

9. 통합 Security Controls 카탈로그 (/controls)

- 단일 보안 통제 관리: `SEC-ENC-001` 등 표준 보안 통제 코드와 제목/설명 관리
- 영향 범위 (Blast Radius) 추적: 해당 Control이 연결된 체크리스트 템플릿 및 적용된 심의 건수를 실시간 추적

10. 체크리스트 템플릿 관리 (/templates)

템플릿 관리
체크리스트 원본과 게시 버전을 관리합니다

체크리스트 템플릿
게시 버전은 직접 수정되지 않으며, 새 버전에서만 변경할 수 있습니다.

Excel 가져오기 + 템플릿 생성

- CLOUD**
클라우드 서비스
SecCheck 기본 체크리스트
V1.0 게시 총 1개 버전
복제 편집
- DEVELOPMENT**
개발보안
SecCheck 기본 체크리스트
V2.5 게시 총 1개 버전
복제 편집
- DOCKER**
Docker 보안
SecCheck 기본 체크리스트
V1.0 게시 총 1개 버전
복제 편집
- KUBERNETES**
Kubernetes 보안
SecCheck 기본 체크리스트
V1.0 게시 총 1개 버전
복제 편집
- PRIVACY**
개인(신용)정보
SecCheck 기본 체크리스트
V1.0 게시 총 1개 버전
복제 편집

- 기본 탑재 템플릿: 개발보안, 개인(신용)정보보호, 클라우드 보안, Docker/Kubernetes 컨테이너 보안 템플릿 자동 시딩
- 버전 분리 원칙: 게시된 버전은 수정 불가능하며, 새 버전 생성을 통해서만 안전하게 변경 관리

11. 템플릿 상세 및 카테고리/항목 편집 (/templates/:id)

SecCheck

SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자 역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

템플릿 편집

초안 항목과 버전을 관리합니다

admin

admin

← 템플릿

+ 새 버전

버전 비교

클라우드 서비스

CLOUD · SecCheck 기본 체크리스트

V1.0 · PUBLISHED

게시

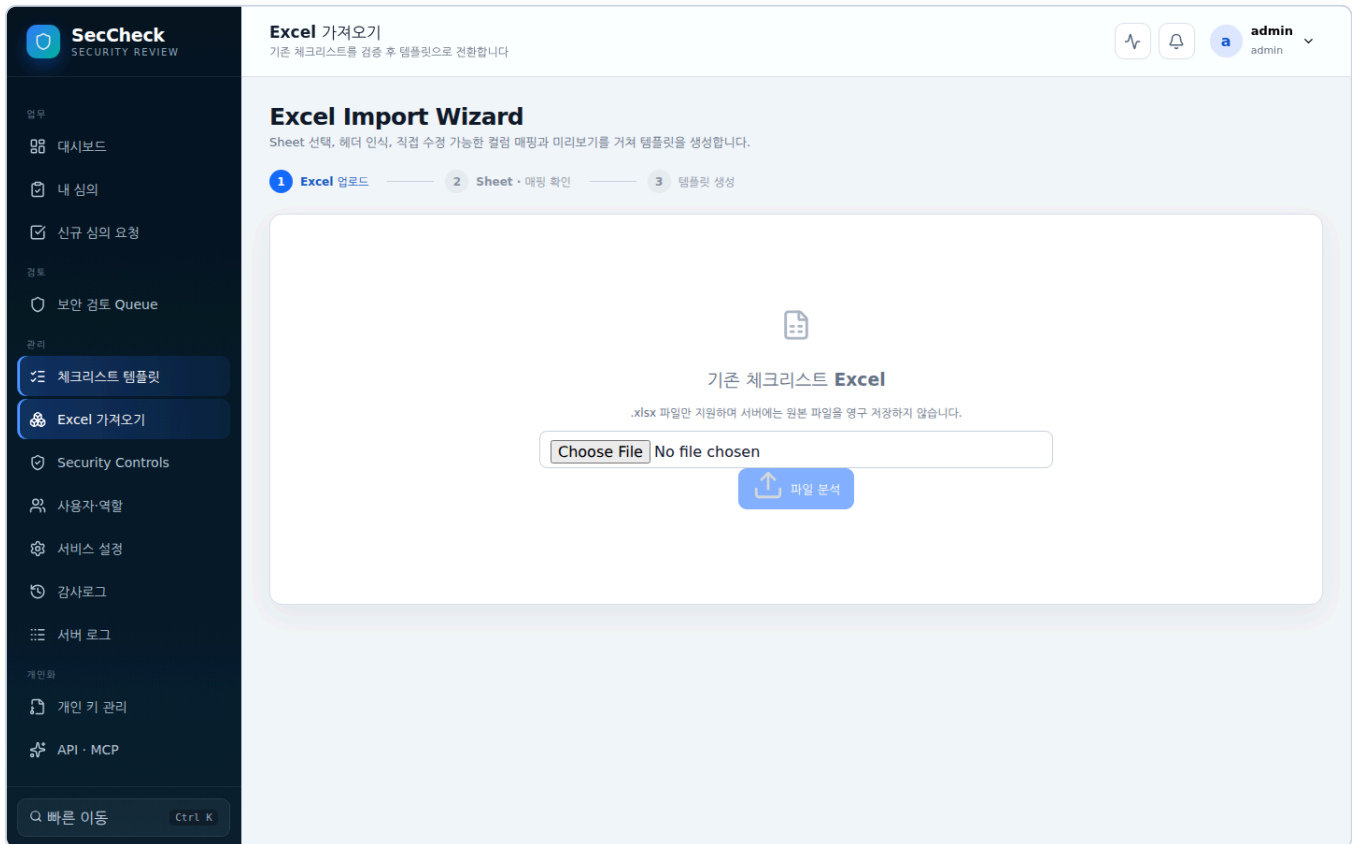
기본 체크리스트 자동 등록

변경 이력

순서	코드	섹션	보안요건	중요도	입력 유형	필수
1	CLOUD-001	공통	바이러스, 웜, 트로이목마 등의 악성코드 탐지 및 차단 기술 적용하고 있는가? 바이러스, 웜, 트로이목마 등의 악성코드 탐지 및 차단 기술 적용하고 있는가?	MEDIUM	YNNA	필수
2	CLOUD-002	공통	가상환경에서 이상징후 발견 시 사용 중지 및 격리 체계 마련하고 있는가? 가상환경에서 이상징후 발견 시 사용 중지 및 격리 체계 마련하고 있는가?	MEDIUM	YNNA	필수
3	CLOUD-003	가상화보안	가상자원의 생성, 변경, 회수 등에 대한 관리방안 마련하고 있는가? 가상자원의 생성, 변경, 회수 등에 대한 관리방안 마련하고 있는가?	MEDIUM	YNNA	필수
4	CLOUD-004	가상화보안	가상자원에 대한 무결성 보장을 위한 보호조치 및 변경 내역 모니터링을 하고 있는가? 가상자원에 대한 무결성 보장을 위한 보호조치 및 변경 내역 모니터링을 하고 있는가?	MEDIUM	YNNA	필수
5	CLOUD-005	가상화보안	호스트OS 및 가상화관리 소프트웨어 모니터링 및 패치를 포함한 악성코드 방지대책 마련하고 있는가? 호스트OS 및 가상화관리 소프트웨어 모니터링 및 패치를 포함한 악성코드 방지대책 마련하고 있는가?	MEDIUM	YNNA	필수
6	CLOUD-006	가상화보안	가상화 실행 이력의 안전한 저장·관리 방안을 수립하고 있는가? 가상화 실행 이력의 안전한 저장·관리 방안을 수립하고 있는가?	MEDIUM	YNNA	필수
7	CLOUD-007	가상화보안	가상화 OS의 내/외부 데이터 이용에 대한 로그 관리를 하고 있는가? 가상화 OS의 내/외부 데이터 이용에 대한 로그 관리를 하고 있는가?	MEDIUM	YNNA	필수
8	CLOUD-008	가상화보안	하드웨어, 가상 이미지, 가상화 관리 소프트웨어(하이퍼바이저 등)에 대한 잠재적 위협을 고려하여 취약점 점검, 보안 모니터링 등을 하고 있는가? 하드웨어, 가상 이미지, 가상화 관리 소프트웨어(하이퍼바이저 등)에 대한 잠재적 위협을 고려하여 취약점 점검, 보안 모니터링 등을 하고 있는가?	MEDIUM	YNNA	필수
9	CLOUD-009	가상화보안	호스트와 가상영역간 경계를 명확하게 구분하며, 가상머신 자원의 남용 방지를 하고 있는가? 호스트와 가상영역간 경계를 명확하게 구분하며, 가상머신 자원의 남용 방지를 하고 있는가?	MEDIUM	YNNA	필수

- 카테고리 & 항목 구성: 보안 요건, 질문, 가이드, 작성 예시, 법적 근거, 가중치, 증거 필수 여부 정의
- Rule Engine 조건 지정: 특정 서비스 특성(개인정보, 클라우드, K8s 등)일 때만 자동 배정되도록 조건 규칙 설정

12. Excel Import Wizard (/templates/import)



- **기존 엑셀 자산 변환:** 기존 엑셀 체크리스트 파일을 업로드하고 컬럼(항목코드, 요건명, 질문, 점검기준 등)을 매핑하여 신규 템플릿으로 즉시 변환

13. 개인 프로필 (/profile)

SecCheck
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

SecCheck
보안성 심의 관리

개인 프로필

개인화 설정은 서비스 관리자 설정과 분리되어 있습니다.

기본정보

사용자명

admin

인증 원본

LOCAL

표시 이름

admin

이메일

부서

역할

APPROVER

AUDITOR

REQUESTER

SECURITY_REVIEWER

SYSTEM_ADMIN

TEMPLATE_ADMIN

저장

- 계정 정보: 표시 이름, 이메일, 부서, 인증 원본(로컬/OIDC), 부여된 RBAC 역할 확인 및 정보 변경

14. 개인 키 관리 & 증적 암호화 키 회전 (/profile/keys)

SecCheck
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

개인 키 관리
개인 API 키와 암호화 키를 회전합니다

개인 키 관리

시스템 연계 API 키와 개인 증적 암호화 키를 독립적으로 회전합니다.

개인 API 키

Bearer

발급한 API 키가 없습니다.

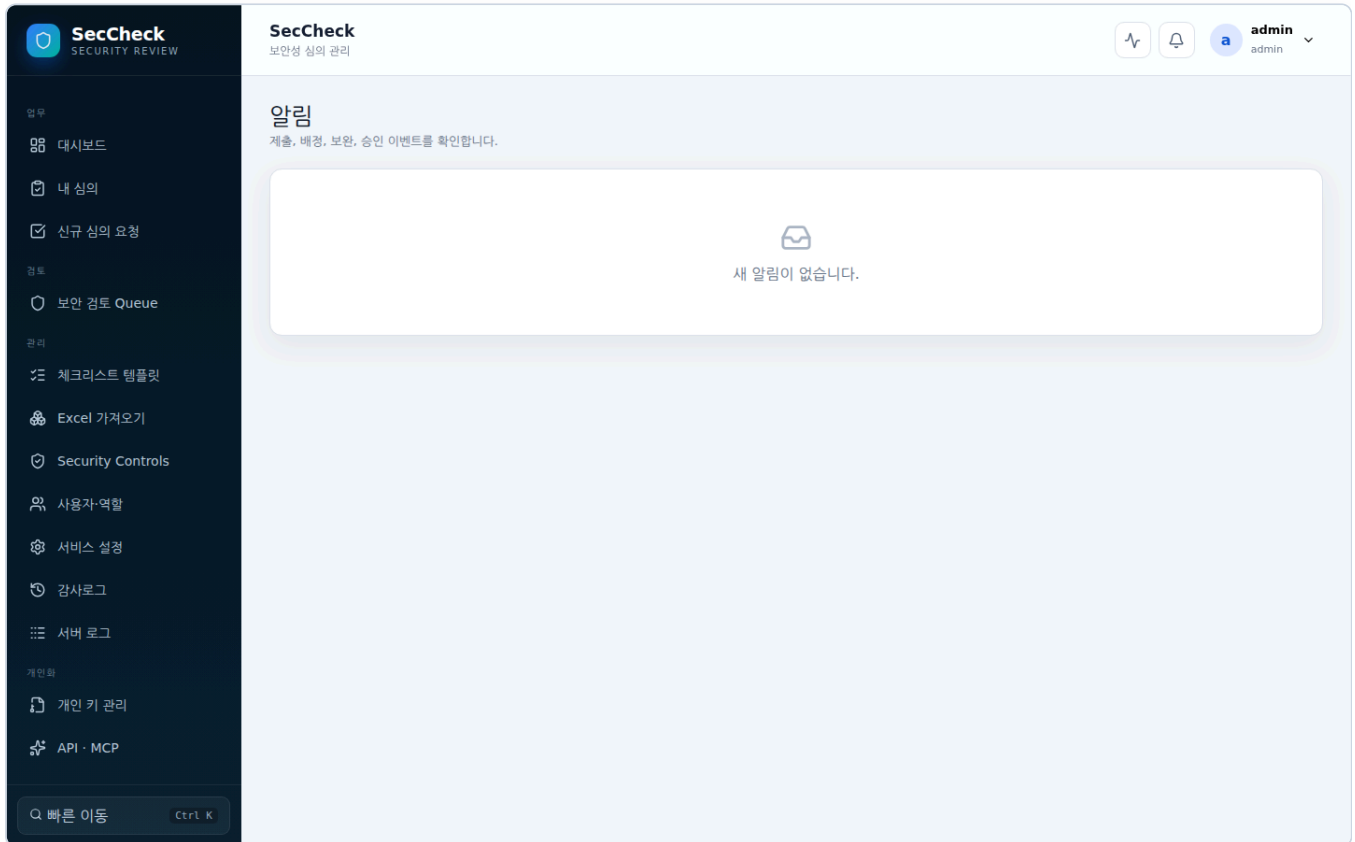
개인 증적 암호화 키

증적은 업로드 사용자의 개인 데이터 키로 암호화되고 키 버전이 파일 메타데이터에 저장됩니다. 회전 시 새 증적부터 새 버전을 사용하여 이전 키는 기존 파일 복호화를 위해 안전하게 보관됩니다.

암호화 키 회전

- 개인 **Bearer API 키**: 시스템 연동 및 CI/CD 파이프라인용 API 키 발급, 회전 및 폐기
- 개인 증적 암호화 키 회전 (**Zero-Downtime Data Key Rotation**): 개인 암호화 키를 회전하여 새 증적부터 신규 버전을 적용하며, 이전 키는 기존 증적 복호화를 위해 안전 보관

15. 인앱 알림 센터 (/notifications)



- 심의 이벤트 피드: 심의 제출, 검토자 배정, 보완 요청, 승인/반려 알림 열람 및 읽음 처리

16. API · MCP 연계 가이드 (/integrations)

SecCheck
SECURITY REVIEW

API · MCP
보안 자동화와 AI 에이전트 연계를 구성합니다

API · MCP 연계
Security, IT, AI 자동화를 위한 인증된 인터페이스입니다.

REST API v1

브라우저 세션은 CSRF 보호를 사용하고 시스템 연계는 개인 키의 Bearer 인증을 사용합니다. 모든 API가 Backend에서 RBAC와 객체 접근 권한을 다시 검증합니다.

Authorization: Bearer sck_...

```
curl -H "Authorization: Bearer $KEY" \
http://127.0.0.1:8080/api/v1/review-requests
```

Model Context Protocol 2026-07-28

최신 Stateless Streamable HTTP를 지원하며, 구형 2025-11-25 initialize 클라이언트도 호환합니다. 개인 API 키를 Authorization 헤더에 설정하세요.

Endpoint
`http://127.0.0.1:8080/mcp`

제공 도구

- seccheck.dashboard
- seccheck.list_reviews
- seccheck.get_review
- seccheck.search_controls
- seccheck.validate_submission

AI 연계 안전 원칙

최소 권한
사용자의 API 키 권한과 심의 Row 접근 범위가 MCP에도 동일하게 적용됩니다.

읽기 전용 도구
현재 MCP 도구는 조회·검증 전용이며, 상태 변경은 서비스 UI에서 사람이 확인합니다.

완전한 감사
MCP 도구 호출도 사용자, 도구명, 요청 ID와 함께 감사로그에 기록됩니다.

SecCheck vv0.1.0

API · MCP

빠른 이동 Ctrl K

- **REST API & OpenAPI 3.1:** 엔드포인트 명세 및 Bearer 인증 가이드
- **Model Context Protocol (MCP):** 2026-07-28 Stateless Streamable HTTP 지원 및 5대 도구 연동 안내

17. 서비스 관리자: 사용자 및 역할 관리 (/admin/users)

SecCheck SECURITY REVIEW

사용자·역할
RBAC 사용자와 최소 권한을 관리합니다.

사용자 및 역할
RBAC 역할을 조합하고 비활성 계정의 세션을 즉시 종료합니다.

+ 로컬 사용자

사용자	부서	인증	역할	상태
admin admin ·	-	LOCAL	승인자 검사자 심의 요청자 보안 담당자 시스템 관리자 체크리스트 관리자	활성 ○ 역할

빠른 이동 Ctrl K

- **RBAC 7대 역할 체계:** SYSTEM_ADMIN , TEMPLATE_ADMIN , SECURITY_REVIEWER , REQUESTER , CONTRIBUTOR , APPROVER , AUDITOR 조합 및 활성/비활성 즉시 제어

18. 서비스 관리자: 시스템 설정 (/admin/settings)

 **SecCheck**
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

   **admin**
admin

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

서비스명

SecCheck

표시 시간대

Asia/Seoul

세션 시간(분)

480

보존 기간(일)

1825

변경 사항은 감사로그에 기록됩니다.

 **SecCheck**
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

   **admin**
admin

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

Keycloak / OIDC SSO 활성화

☐

Issuer URL

https://keycloak.example/realms/company

Client ID

Client Secret

Callback URL

https://seccheck.example/api/v1/auth/oidc/callback

Keycloak confidential client secret

사용자명 Claim

preferred_username

신규 사용자 기본 역할

REQUESTER

Discovery 연결 테스트

변경 사항은 감사로그에 기록됩니다.

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

admin

admin

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

설정 저장

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

HTTPS 전용 Secure Cookie

본당 요청 제한

120

장기 미접속 관리자 잠금(일)

90

CORS 허용 Origin

참조로 구분, 예: https://fsm.example

변경 사항은 감사로그에 기록됩니다.

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

admin

admin

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

설정 저장

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

이메일 알림 활성화

SMTP 호스트

SMTP 포트

25

전송 보안

STARTTLS

SMTP 사용자

SMTP 비밀번호

발신 주소

이메일은 PostgreSQL 작업 큐에서 재시도되며, 실패 건수는 /metrics와 서버 로그에서 확인할 수 있습니다.

변경 사항은 감사로그에 기록됩니다.

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

admin

admin

설정 저장

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반 검토·승인 Keycloak OIDC 파일 보안 접근 보안 알림

팀장/승인자 최종 승인 프로세스

검토자 배정 필수

승인 프로세스가 꺼져 있으면 보안 담당자의 검토 완료가 즉시 최종 심의 완료로 처리됩니다. 켜져 있으면 APPROVAL_PENDING 상태에서 승인자에게 전달됩니다.

변경 사항은 감사로그에 기록됩니다.

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자·역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

admin

admin

설정 저장

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반 검토·승인 Keycloak OIDC 파일 보안 접근 보안 알림

최대 파일 크기(MB)

25

허용 확장자

pdf, png, jpg, jpeg, xlsx, xls, docx, zip, txt, json

ClamAV 악성코드 검사

ClamAV 주소

clamav:3310

파일은 확장자와 실제 Magic/MIME을 함께 검증한 뒤 UUID 파일명으로 AES-256-GCM 암호화 저장됩니다.

변경 사항은 감사로그에 기록됩니다.

- 일반 설정: 세션 시간, 데이터 보존 기간(일), 표시 시간대
- 검토·승인 워크플로: 팀장/승인자 최종 승인 프로세스 On/Off, 검토자 배정 필수 정책
- Keycloak OIDC SSO: Issuer Discovery, Client Secret(암호화 보관), 그룹 매핑, 연결 테스트
- 파일 보안 & ClamAV: 최대 파일 크기, 허용 확장자 화이트리스트, ClamAV 데몬 주소 및 악성코드 차단
- 접근 보안: HTTPS Secure Cookie, Rate Limiting, 장기 미접속 관리자 잠금, CORS Origin

- 알림 (SMTP): 호스트, 포트, STARTTLS/TLS, SMTP 인증 정보 및 발신 주소

19. 서비스 관리자: 해시 체인 불변 감사로그 (/admin/audit)

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자-역할

서비스 설정

감사로그

서버 로그

계정 관리

개인 키 관리

API · MCP

빠른 이동

Ctrl K

감사로그

중요 행위의 해시 체인 이력을 확인합니다

감사로그

이전 이벤트 해시를 연결한 위변조 탐지 체인입니다. 애플리케이션에서 수정-삭제 API를 제공하지 않습니다.

이벤트 유형 필터

시각

이벤트

사용자 / IP

대상

결과

해시

2026. 08. 14. 오후 07:57	VIEW_SUBMISSION	admin 127.0.0.1	REVIEW_REQUEST 074d674e-8b56-46b2-a43b-917f3bb620e9	SUCCESS	136f66f4d843...
2026. 08. 14. 오후 07:57	UPDATE_RESPONSE	admin 127.0.0.1	SUBMISSION_ITEM 150fc53a-77b4-45b9-bc0d-181cfe3d3bcf	SUCCESS	5fdd79e06c6d...
2026. 08. 14. 오후 07:57	UPDATE_RESPONSE	admin 127.0.0.1	SUBMISSION_ITEM 6a332822-167e-43ac-8cbe-349fa8b402ea	SUCCESS	8d63fdeab07b...
2026. 08. 14. 오후 07:57	CREATE_SUBMISSION	admin 127.0.0.1	REVIEW_REQUEST 0266b022-f541-4d83-b4a2-caf0a778d9d9	SUCCESS	5a4b9e1e024f...
2026. 08. 14. 오후 07:57	CREATE_SUBMISSION	admin 127.0.0.1	REVIEW_REQUEST 074d674e-8b56-46b2-a43b-917f3bb620e9	SUCCESS	54b1452b6bdb...
2026. 08. 14. 오후 07:57	LOGIN	admin 127.0.0.1	USER ce5c6243-213d-4ea6-be52-84393ae007a6	SUCCESS	eea35b87f221...
2026. 08. 14. 오후 07:56	VIEW_SUBMISSION	admin 127.0.0.1	REVIEW_REQUEST 14ead524-095b-4d99-9b93-66b0640b8b47	SUCCESS	cd725f79aa4c...
2026. 08. 14. 오후 07:56	UPDATE_RESPONSE	admin 127.0.0.1	SUBMISSION_ITEM edacf5d6-5114-4b9d-94df-5a0026fb7b08	SUCCESS	61dd957dece4...
2026. 08. 14. 오후 07:56	UPDATE_RESPONSE	admin 127.0.0.1	SUBMISSION_ITEM 67c43f5e-a25e-483e-b18f-5e2b7e7f82d6	SUCCESS	745981895968...
2026. 08. 14. 오후 07:56	CREATE_SUBMISSION	admin 127.0.0.1	REVIEW_REQUEST 705bde41-b69e-487b-9df7-10ed380c30c8	SUCCESS	8bd53e61d677...
2026. 08. 14. 오후 07:56	CREATE_SUBMISSION	admin 127.0.0.1	REVIEW_REQUEST 14ead524-095b-4d99-9b93-66b0640b8b47	SUCCESS	c0aed34c7099...

- 암호학적 해시 체인 (Hash Chaining): 이전 이벤트 해시(prev_hash)를 연결하여 위변조를 원천 차단
- 원클릭 체인 검증 (체인 검증): 전체 감사 이벤트의 무결성을 실시간으로 검증

21

20. 서비스 관리자: 구조화 서버 로그 (/admin/logs)

 **SecCheck**
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Security Controls

사용자 역할

서비스 설정

감사로그

서버 로그

개인화

개인 키 관리

API · MCP

빠른 이동 Ctrl K

서버 로그

구조화된 애플리케이션 로그를 확인합니다

전체 레벨

새로고침

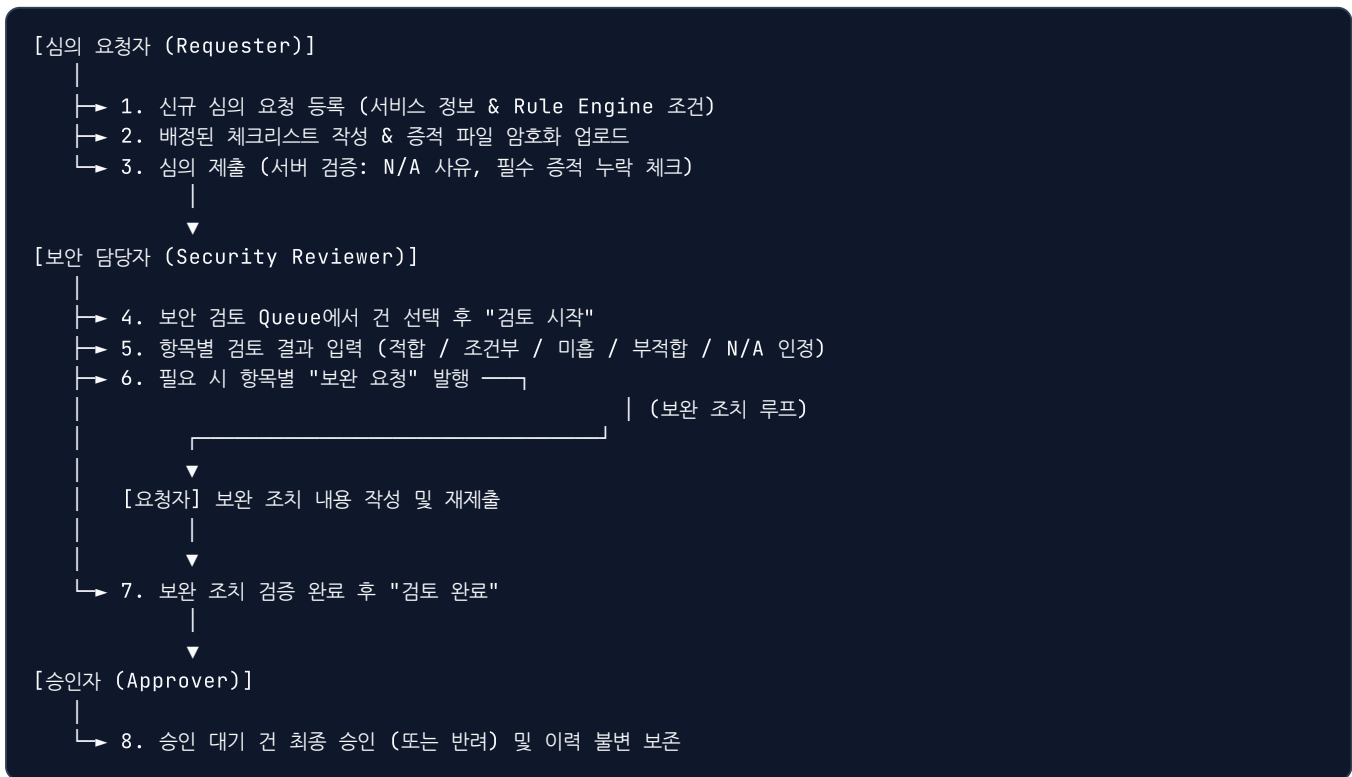
시각	레벨	구성요소	메시지	요청 ID
2026. 08. 14. 오후 07:58	INFO	http	HTTP request {"duration_ms":14,"method":"GET","path":"/api/v1/me","status":200}	21513610-8d72-4f89-bc06-ca200f213d3a
2026. 08. 14. 오후 07:58	INFO	http	HTTP request {"duration_ms":5,"method":"GET","path":"/api/v1/public/config","status":200}	3ed958bd-ec9c-4783-8302-248a98a90f45
2026. 08. 14. 오후 07:58	INFO	http	HTTP request {"duration_ms":10,"method":"GET","path":"/api/v1/admin/audit","status":200}	7577cad4-e491-4234-b5b5-1cddd54c6af
2026. 08. 14. 오후 07:58	INFO	http	HTTP request {"duration_ms":10,"method":"GET","path":"/api/v1/me","status":200}	0b7f533f-e3ca-4cad-bfe5-8e3c38a459a2
2026. 08. 14. 오후 07:58	INFO	http	HTTP request {"duration_ms":1,"method":"GET","path":"/api/v1/public/config","status":200}	7f70f679-5c73-4881-bc4c-2f1e80d1331c
2026. 08. 14. 오후 07:57	INFO	http	HTTP request {"duration_ms":13,"method":"GET","path":"/api/v1/admin/settings","status":200}	80f65604-e091-43b7-9a55-6b0d0fb5df7d
2026. 08. 14. 오후 07:57	INFO	http	HTTP request {"duration_ms":4,"method":"GET","path":"/api/v1/me","status":200}	d4cd81f1-b73d-413e-aecb-4f7441696f61
2026. 08. 14. 오후 07:57	INFO	http	HTTP request {"duration_ms":0,"method":"GET","path":"/api/v1/public/config","status":200}	b12a5077-d43c-4767-81bb-26fb1de5d496
2026. 08. 14. 오후 07:57	INFO	http	HTTP request {"duration_ms":14,"method":"GET","path":"/api/v1/admin/users","status":200}	6876ebbd-85e8-4628-b0dc-1732915748f3

- 민감정보 마스킹 구조화 로그: 요청 ID(Request ID), 레벨(INFO/WARN/ERROR), 구성요소별 로그 실시간 조회

SecCheck 사용자 실무 가이드 (User Guide)

SecCheck 는 심의 요청자, 보안 담당자, 승인자가 하나의 시스템에서 유기적으로 소통하며 보안성 심의를 완결할 수 있도록 지원합니다.

1. 역할별 핵심 업무 흐름



2. 심의 요청자 (Requester) 실무

1. 신규 심의 요청 생성

- 대시보드 또는 심의 목록에서 **신규 심의** 버튼을 클릭합니다.
- 서비스 기본정보를 입력합니다:
 - 서비스명, 담당 부서, 서비스 설명, 서비스 유형(대내/대외/관리자/배치), 신규·변경 구분, 오픈 예정일
- **적용 조건 (Rule Engine)****을 체크합니다:
 - 관리자 페이지 여부, 개인정보/신용정보 처리 여부, 클라우드/Docker/K8s 사용 여부, 외부 연계 및 인터넷 통신 여부
- 심의 생성 및 항목 배정** 버튼을 클릭하면, 등록된 최신 템플릿에서 조건에 맞는 항목들이 스냅샷으로 자동 배정됩니다.

2. 체크리스트 작성 및 증거 첨부

- 적용 여부 (**Y** / **N** / **N/A**):
 - Y** : 요건을 충족하는 경우 선택하고 자체 판단(**적합**) 및 적용 현황을 작성합니다.
 - N/A** : 해당 요건이 서비스에 적용되지 않는 경우 선택하며, **N/A 사유**를 반드시 입력해야 제출이 가능합니다.

- 실시간 자동 저장: 입력 중 1.2초 후 자동으로 백그라운드에 저장되며 우측 상단에 **✓ 자동 저장** 상태가 표시됩니다.
- 증거 파일 업로드:
 - **증거 첨부** 섹션에서 파일을 선택하고 설명을 입력한 뒤 **암호화 업로드**를 클릭합니다.
 - 파일은 확장자와 Magic/MIME 검증 후 AES-256-GCM으로 암호화 저장됩니다.
 - 파일 변경 시 **새 버전** 버튼으로 이력을 덮어쓰지 않고 버전별로 보존할 수 있습니다.

3. 심의 제출 및 누락 검증

- 모든 필수 항목을 작성한 후 우측 상단의 **제출** 버튼을 클릭합니다.
- 서버 제출 검증:
 - N/A 사유 누락, 필수 증거 미첨부, 미작성 항목이 발견되면 모달 팝업으로 누락 목록을 정확히 안내하여 결함을 사전 예방합니다.

4. 보완 요청 대응 및 재제출

- 보완 담당자가 보완을 요청한 항목에는 주황색 **보완 요청** 배지가 표시됩니다.
- 보완 사유를 확인하고 조치 내용 작성 및 추가 증거를 첨부한 뒤 **조치 완료**를 누르고 **재제출** 합니다.

3. 보안 담당자 (Security Reviewer) 실무

1. 보안 검토 Queue (/security)

- 제출(**SUBMITTED**) 또는 재제출(**RESUBMITTED**)된 심의 건을 확인하고 **검토** 버튼을 누릅니다.
- 상단의 **검토 시작** 버튼을 누르면 상태가 **REVIEWING**으로 전환됩니다.

2. 항목별 검토 및 판정

- 항목을 선택하고 우측의 가이드, 법적 근거, 첨부된 증거 파일을 검토합니다.
- **보안 담당자 검토** 섹션에서 다음을 판정합니다:
 - 최종 적용 여부: 작성자 판단 유지 또는 **Y / N / N/A**로 조정
 - 검토 결과: **적합(COMPLIANT)**, **조건부 적합(CONDITIONAL)**, **미흡(INSUFFICIENT)**, **부적합(NON_COMPLIANT)**, **N/A 인정(NA_ACCEPTED)**, **재확인(RECHECK)**
 - 증거 적정성: **적정(ADEQUATE)**, **일부 보완(PARTIAL)**, **부적정(INADEQUATE)**
 - 검토 의견 및 후속조치 작성 후 **검토 저장** 클릭

3. 항목 보완 요청 및 검증

- 미흡한 항목은 **보완 요청** 버튼을 눌러 보완 사유와 완료 기한을 지정합니다.
- 요청자가 조치를 완료하면 **조치 검증** 버튼을 눌러 상태를 **VERIFIED**로 변경합니다.
- 모든 항목 검토가 끝나면 **검토 완료** 버튼을 누릅니다.

4. 승인자 (Approver) 실무

- 관리자 설정에서 **승인 프로세스**가 켜져 있는 경우, 검토가 완료된 건은 **APPROVAL_PENDING** 상태로 승인자에게 전달됩니다.
- 심의 상세 상단의 **최종 승인** 또는 **반려** 버튼을 클릭하고 의견을 남겨 의사결정을 완료합니다.

5. 심의 결과물 내보내기 (Export)

심의 상세 상단의 내보내기 버튼을 통해 3가지 형식의 최종 보고서를 다운로드할 수 있습니다:

포맷	파일 확장자	내용 및 용도
Excel	.xlsx	전 항목 체크리스트, 자체 판단, 검토 결과, 코멘트가 서식화된 엑셀 보고서
PDF	.pdf	감사 및 대외 제출용 공식 보안성 심의 완료 증명서 (A4 규격)
ZIP	.zip	심의 보고서와 암호화 복호화된 전체 첨부 증거 파일 압축 패키지

SecCheck 관리자 운영 가이드 (Admin Guide)

SecCheck 는 오프라인 폐쇄망 및 엔터프라이즈 환경에서 외부 의존성 없이 안정적으로 동작하도록 설계된 보안 검토 플랫폼입니다.

1. 런타임 환경변수 4종

서비스 구동 시 필요한 환경변수는 정확히 다음 4개뿐이며, 그 외 모든 정책은 관리자 웹 콘솔에서 런타임으로 관리됩니다:

환경변수명	필수 여부	설명	예시
POSTGRES_DSN	필수	PostgreSQL 연결 DSN (<code>sslmode=verify-full</code> 권장)	<code>postgres://seccheck:pass@postgres:5432/seccheck?sslmode=disable</code>
BOOTSTRAP_ADMIN	필수	초기 로컬 관리자 아이디	<code>admin</code>
BOOTSTRAP_ADMIN_PASSWORD	필수	초기 관리자 비밀번호 (최소 12자 이상)	<code>ComplexPassword123!</code>
ENCRYPTION_KEY	필수	비밀값 및 데이터 키 암호화용 32바이트 Master Key	<code>01234567890123456789012345678901</code>

2. Keycloak OIDC SSO 엔터프라이즈 연동

SecCheck 는 표준 OpenID Connect Discovery를 통해 사내 Keycloak과 원클릭으로 연동됩니다.

1. Keycloak Client 설정:

- Client Type: `OpenID Connect`
- Client Authentication: `ON` (Confidential)
- Standard Flow: `ON`
- Valid Redirect URIs: `https://<seccheck-host>/api/v1/auth/oidc/callback`

2. 관리자 콘솔 설정 (`/admin/settings` → `Keycloak OIDC`):

- Keycloak / OIDC SSO 활성화 `ON`
- Issuer URL: `https://keycloak.company.internal/realms/enterprise`
- Client ID & Client Secret: Keycloak 발급 자격증명 입력 (AES-256-GCM 암호화 보관)
- Callback URL: `https://seccheck.company.internal/api/v1/auth/oidc/callback`
- 사용자명 Claim: `preferred_username`

- 기본 역할: REQUESTER

3. 연결 테스트:

- Discovery 연결 테스트 버튼을 클릭하여 엔드포인트 도달 가능 여부를 실시간 검증합니다.

3. RBAC 7대 역할 체계

역할 코드	한글 명칭	권한 범위
SYSTEM_ADMIN	시스템 관리자	서비스 설정, 사용자 및 역할 관리, 감사로그 열람 및 체인 검증
TEMPLATE_ADMIN	체크리스트 관리자	템플릿 생성/편집/게시, Security Control 등록, Excel 가져오기
SECURITY_REVIEWER	보안 담당자	보안 검토 Queue 조회, 검토 시작, 판정, 보완 요청 및 검증 완료
APPROVER	승인자	최종 승인 및 반려 의사결정 권한
REQUESTER	심의 요청자	신규 심의 생성, 체크리스트 작성, 증적 업로드, 제출 및 재제출
CONTRIBUTOR	공동 작성자	배정된 심의의 체크리스트 공동 작성 및 증적 첨부
AUDITOR	감사자	모든 심의 및 감사로그 읽기 전용 열람 권한

4. 파일 업로드 보안 & ClamAV 안티바이러스

- **Magic/MIME & 확장자 교차 검증:** 파일 확장자 위변조(예: .exe 를 .pdf 로 변경)를 서버 레벨에서 차단합니다.
- **AES-256-GCM 암호화 보관:** 모든 증적은 서버 디스크에 UUID 파일명으로 암호화되어 저장됩니다.
- **ClamAV 악성코드 검사:**
 - 관리자 설정에서 ClamAV 악성코드 검사 활성화 및 clamav:3310 데몬 주소 입력
 - ClamAV 검사 실패 또는 악성코드 탐지 시 파일 업로드는 즉시 차단(Fail-Closed)됩니다.

5. 암호학적 해시 체인 감사로그 무결성 검증

- 해시 체인 구조:
 - 모든 행위(로그인, 심의 생성, 수정, 제출, 판정, 승인, 설정 변경, 키 회전)는 이전 이벤트의 해시(prev_hash)와 결합되어 SHA-256 해시 체인을 형성합니다.
 - 데이터베이스 직접 조작이나 위변조가 발생할 경우 체인이 즉시 깨집니다.
- 체인 검증 실행 (/admin/audit):
 - 체인 검증 버튼을 누르면 서버가 전체 이벤트의 암호학적 링크를 전수 검사하여 "N개 감사 이벤트의 해시 체인이 유효합니다." 결과를 반환합니다.

6. 관측성 및 Prometheus 모니터링

엔드포인트	메서드	용도	설명
/health	GET	Liveness Probe	프로세스 생존 여부 확인
/ready	GET	Readiness Probe	DB 풀 및 테이블 쿼리 가능 상태 확인
/metrics	GET	Prometheus Metrics	API 요청수, 지연시간, 심의 상태별 통계, 증적 저장량, 실패 작업 수 수집
/mcp	POST	Model Context Protocol	AI 에이전트 연계 인터페이스 (2026-07-28)

SecCheck API & MCP 연계 가이드 (API & MCP Guide)

SecCheck 는 시스템 연계 및 CI/CD 자동화를 위한 **REST API**와 AI 에이전트(Claude Desktop, Cursor 등) 연동을 위한 **Model Context Protocol (MCP)** 인터페이스를 제공합니다.

1. 인증 체계 (Authentication)

모든 API 및 MCP 호출은 개인 키 관리(`/profile/keys`)에서 발급받은 **Bearer API Key** 또는 세션 쿠키를 사용합니다:

```
Authorization: Bearer sck_a1b2c3d4_XXXXXXXXXXXXXXXXXXXXXXXXXXXX
```

2. REST API 주요 엔드포인트 (`/api/v1`)

📋 심의 요청 및 관리 (Review Requests)

메서드	경로	설명	권한
GET	<code>/review-requests</code>	심의 목록 조회 (필터: <code>q</code> , <code>status</code>)	<code>REQUESTER</code> , <code>SECURITY_REVIEWER</code>
POST	<code>/review-requests</code>	신규 심의 생성 및 Rule Engine 자동 배정	<code>REQUESTER</code> , <code>SYSTEM_ADMIN</code>
GET	<code>/review-requests/{id}</code>	심의 상세 정보 및 진행 통계 조회	담당자, 검토자, 승인자
GET	<code>/review-requests/{id}/items</code>	심의에 배정된 체크리스트 항목 및 답변 목록	담당자, 검토자, 승인자
PUT	<code>/review-requests/{id}/responses/{itemID}</code>	체크리스트 항목 작성 및 자동 저장	<code>REQUESTER</code> , <code>CONTRIBUTOR</code>
POST	<code>/review-requests/{id}/submit</code>	심의 제출 (서버 검증 실행)	<code>REQUESTER</code>
POST	<code>/review-requests/{id}/begin-review</code>	보안 검토 시작 (<code>REVIEWING</code> 전환)	<code>SECURITY_REVIEWER</code>
PUT	<code>/review-requests/{id}/review-results/{itemID}</code>	항목별 검토 결과 및 의견 저장	<code>SECURITY_REVIEWER</code>
POST	<code>/review-requests/{id}/approve</code>	심의 최종 승인	<code>APPROVER</code>
POST	<code>/review-requests/{id}/reject</code>	심의 반려	<code>APPROVER</code>

📎 증거 파일 (Evidences)

메서드	경로	설명	권한
POST	/review-requests/{id}/items/{itemID}/evidences	증거 파일 암호화 업로드 (multipart/form-data)	REQUESTER , CONTRIBUTOR
GET	/evidences/{id}/download	증거 파일 복호화 다운로드	권한자
POST	/evidences/{id}/versions	증거 파일 신규 버전 교체 등록	REQUESTER , CONTRIBUTOR

🛡️ 통합 Security Controls & 템플릿

메서드	경로	설명	권한
GET	/security-controls	통합 Security Control 목록 및 영향 통계	전체
GET	/security-controls/{id}/impact	특정 Control 변경 시 영향 받는 템플릿/심의 조회	TEMPLATE_ADMIN
GET	/templates	체크리스트 템플릿 목록 및 게시 버전 조회	전체

3. Model Context Protocol (MCP) 엔드포인트

- 엔드포인트: POST /mcp
- 프로토콜 버전: MCP 2026-07-28 Stateless Streamable HTTP (구형 2025-11-25 호환)
- 인증: Authorization: Bearer <API_KEY>

🔧 제공 도구 목록 (Tools)

1. seccheck.dashboard : 대시보드 통계 및 긴급 처리 건수 조회
2. seccheck.list_reviews : 상태 및 키워드 기반 심의 목록 검색
3. seccheck.get_review : 특정 심의의 상세 정보, 진행률, 체크리스트 항목 조회
4. seccheck.search_controls : Security Control 및 체크리스트 가이드 검색
5. seccheck.validate_submission : 제출 전 누락 항목 및 결함 사전 검증

💬 MCP 호출 예시 (JSON-RPC 2.0)

요청: 심의 제출 전 결함 사전 검증

```
{
  "jsonrpc": "2.0",
  "id": "req-201",
  "method": "tools/call",
  "params": {
    "name": "seccheck.validate_submission",
    "arguments": {
      "review_id": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d"
    }
  }
}
```

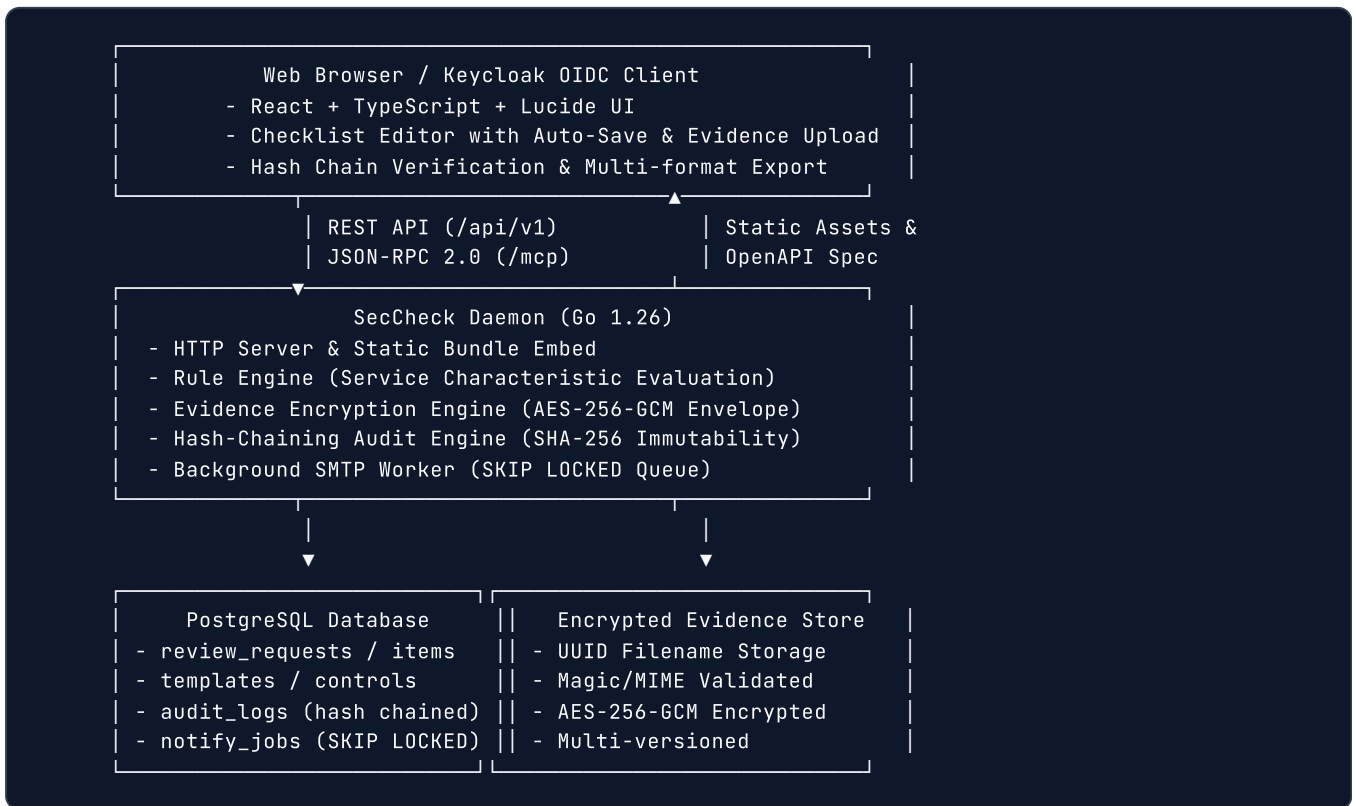
응답

```
{
  "jsonrpc": "2.0",
  "id": "req-201",
  "result": {
    "content": [
      {
        "type": "text",
        "text": "검증 결과: 제출 가능한 상태입니다. (작성 완료: 45/45, 필수 증거 첨부: 12건)"
      }
    ]
  }
}
```

SecCheck 시스템 아키텍처 및 보안 설계 (Architecture)

SecCheck 는 오프라인 폐쇄망에서 단일 바이너리와 PostgreSQL만으로 영구 지속되는 안정성을 보장하도록 설계되었습니다.

1. 시스템 아키텍처 다이어그램



2. 핵심 보안 및 설계 불변 원칙

1. 템플릿-버전-스냅샷 3계층 분리 불변 모델

- **Template:** 체크리스트의 최상위 컨테이너
- **Version:** 게시(**PUBLISHED**) 시점의 불변 체크리스트 버전
- **Snapshot (Review Items):** 심의 생성 시점에 배정된 항목들은 템플릿 원본이 추후 변경되더라도 결코 바뀌지 않는 독립 스냅샷으로 영구 보존됩니다.

2. 증거 파일 암호화 파이프라인 (Evidence Encryption)

1. **Magic/MIME 교차 검증:** 파일의 실제 바이트 헤더를 검사하여 확장자 변조 방지
2. **SHA-256 해시 계산:** 무결성 검증을 위한 해시 생성
3. **AES-256-GCM 봉투 암호화:** 사용자의 개인 데이터 키(**user_data_keys**)로 암호화 후 디스크에 UUID로 저장
4. **무중단 키 회전:** 개인 암호화 키를 회전해도 이전 버전 증거는 계속 안전하게 복호화 지원

3. 암호학적 해시 체인 감사로그 (Cryptographic Hash Chaining)

- 모든 행위는 `SHA256(prev_hash + event_id + timestamp + actor + payload)` 형식으로 연결되어 저장됩니다.
- DB 직접 변조 시 체인이 즉시 파손되어 무결성 검증 단계에서 적발됩니다.